VULNSCAN — Automated Security Intelligence

Security Assessment & Vulnerability Audit Report

Generated on 2026-10-30 21:04:52 UTC | Platform: VulnScan v1.0

Target Project:	DesignSphere	**Security Score:**	**65 / 100**
Target Scope:	https://github.com/kandharipiyush/DesignSphere.git	**Scan Mode:**	COMPREHENSIVE
Scan ID:	#4	**Gate Status:**	**PASS**

1. Executive Summary

VulnScan completed a multi-vector security assessment across static source code (SAST), runtime endpoints (DAST), software dependencies (SCA), and credential exposure checks. The audit identified **5 total finding(s)** across the target scope. Immediate attention is recommended for Critical and High severity findings prior to production deployment.

CRITICAL	HIGH	MEDIUM	LOW	INFO	FIXED
0	**2**	**3**	**0**	**0**	**0**

2. Detailed Vulnerability Findings

#1 Exposed Secret: Supabase Public / Anon API Key — MEDIUM

Category:	Hardcoded Secrets	**CWE / CVE:**	CWE-798
Location:	lib\supabaseClient.ts:4	**Source:**	SECRETS

Technical Evidence:

```
const supabaseAnonKey = process.env.NEXT_PUBLIC_SUPABASE_ANON_KEY ||
"sb_p**********************************9ZIO";
```

Technical Explanation: Credentials committed directly to source control can be discovered by unauthorized parties or extracted from client bundles.

Remediation: Remove credential from source code immediately, revoke/rotate the compromised secret, and use environment variables or a Secret Manager.

#2 Vulnerable Package: @supabase/supabase-js (^2.118.0) - Supabase JS Client LocalStorage Session Persistence Exposure — MEDIUM

Category:	Vulnerable Dependencies	**CWE / CVE:**	CWE-384 CVE-2024-29023
Location:	package.json:1	**Source:**	SCA

Technical Evidence:

```
"@supabase/supabase-js": "^2.118.0"
```

Technical Explanation: Package @supabase/supabase-js version ^2.118.0 is affected by CVE-2024-29023.

Remediation: Run 'npm update @supabase/supabase-js' to upgrade to 2.40.0 or higher.

#3 Vulnerable Package: next (16.4.2) - Next.js Server Actions SSRF & Cache Poisoning Vulnerability HIGH

Category:	Vulnerable Dependencies	**CWE / CVE:**	CWE-918 CVE-2024-34351
Location:	package.json:1	**Source:**	SCA

Technical Evidence:

```
"next": "16.4.2"
```

Technical Explanation: Package next version 16.4.2 is affected by CVE-2024-34351.

Remediation: Run 'npm update next' to upgrade to 14.2.10 or higher.

#4 Vulnerable Package: next-auth (^5.0.0-beta.32) - NextAuth.js Beta Session Fixation & CSRF Token Validation Flaw HIGH

Category:	Vulnerable Dependencies	**CWE / CVE:**	CWE-287 CVE-2024-41662
Location:	package.json:1	**Source:**	SCA

Technical Evidence:

```
"next-auth": "^5.0.0-beta.32"
```

Technical Explanation: Package next-auth version ^5.0.0-beta.32 is affected by CVE-2024-41662.

Remediation: Run 'npm update next-auth' to upgrade to 5.0.0 or higher.

#5 Vulnerable Package: react (19.3.0) - React Server Component Prototype Vulnerability MEDIUM

Category:	Vulnerable Dependencies	**CWE / CVE:**	CWE-79 CVE-2024-4367
Location:	package.json:1	**Source:**	SCA

Technical Evidence:

```
"react": "19.3.0"
```

Technical Explanation: Package react version 19.3.0 is affected by CVE-2024-4367.

Remediation: Run 'npm update react' to upgrade to 18.3.0 or higher.

---

3. DevSecOps Deployment Gate & Next Steps

Deployment Policy Enforcement:

- Critical and High severity findings must be resolved and verified before staging deployment.
- Use VulnScan's AI Security Assistant to review contextual code patches.
- Execute Fix Verification Rescan to mark resolved items and unblock the CI/CD pipeline.